

Module 1

Risk planning looks at

- assets
- threats
- vulnerabilities

Threats negatively impact assets

Likelihood $\times$ impact = Risk

Asset management - tracking assets and risks around them

Asset inventory - catalog of protected assets

Asset classification - categorising assets based on sensitivity and value

- ↳ Public
- ↳ internal
- ↳ confidential
- ↳ Restricted

data states: in use, in transit, at rest

Security Plans

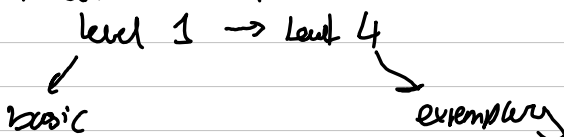
Risks impact CIA of assets

Policy - reduce risk, strategic. Identity Scope

Standards - technical function. References for policies

Procedures - instructions for a specific security task

NIST CSF has 4 levels:



NIST profiles act as industry guidance

Module 2

Security controls

managerial
technical
operational

Data custodian - responsible for handling data

Principle of least privilege - need to know

Data lifecycle:

- ↳ collect
- ↳ store
- ↳ use
- ↳ Archive
- ↳ Destroy

Data steward implements governance policies

Cryptography

Cryptography transforms data so it cannot be easily read through encryption

plaintext $\xrightarrow{\text{encryption}}$ ciphertext $\xrightarrow{\text{decryption}}$ plaintext

Cipher - algorithm that encrypts info

key - a decryption method

PKI - encryption framework to share who encrypts/decrypts. also establishes trust via certificates

Asymmetric encryption - uses a public/private key pair

<u>Symmetric</u>	<u>Asymmetric</u>
3DES	RSA
AES	DSA

Hash function - one way process to encode data

Non-repudiation - integrity cannot be disputed

AAA

Authentication controls work on verifying who a user is

SSO combines several logins into one.

Authorisation controls determine what a user can do.

Separation of duties - users should only have what they need.

OAuth - open-standard authentication protocol to share access between applications

Accounting controls audit systems

Mandatory access control - need to know, network grant

Discretionary access control - decided by owner

Role-based access control - organisations

Module 3

Vulnerabilities

vuln management is identifying and patching vulnerabilities

- ↳ identify vulns
- Consider implications
- Assess
- Patch

0-day - previously unknown exploit

defense - in-depth - multiple layers of unique defenses

- ↳ perimeter layer
- ↳ Network layer
- ↳ endpoint layer
- ↳ application layer
- ↳ data layer

Exposure - mistake that opens up a threat

CVE list - open list of vulns and exposures.

MITRE - non-profit security group

CNA - CVE numbering authority

CVE criteria:

- independent
- Security risk
- with evidence
- only one database

CVSS - Common vulnerability scoring system

↳ scores the severity of a vuln

The CVE list top 10 details the 10 most targeted vulns each year

assessment

assessments identify vulns and find weak points

assessment process:

- identify
- analysis
- Risk assessment
- Remediation

often views are pathways to exploit

defend by educating users
applying principle of least privilege
use the right controls
have a diverse team

Module 4

Social engineering exploits human nature to pull it data extraction or a technical exploit

Stages of Social engineering:

- Pretext
- Trust
- Persuade
- Disconnect

Phishing uses digital communications to exploit an organisation.

Phishing kits: malicious attachments, data collector, web links

malware

- Virus - hide in trusted files or programs
- worm - duplicating malware
- trojan - looks like a legitimate program
- spyware - gather and sell info
- ransomware - demand money

Cryptocurrency is much more popular these days - steal crypto currency and mine coins using an infected machine

web attacks

XSS - injects code into vulnerable website.

XSS → Reflected - sent to server, activated when server
↳ Stored - injected directly to server
↳ DOM based - loads on page load

SQL injection - creates unexpected queries on a database prepared statements - no code being sending it to the server

modelling

Threat modelling looks at the risks, trends, values and compiling all of these.

Steps:

- Define scope
- Identify threats attach tree → threats to assets
- Characterise the environment
- Analyse threats
- Mitigate
- Evaluate

DASTA - Threat modelling framework

Process for Attack Simulation and Threat Analysis

Stage 1: define objectives

Stage 2: define technical scope

Stage 3: Decompose application

Stage 4: threat actors

Stage 5: vuln analysis

Stage 6: attack modelling

Stage 7: analyse and mitigate